SITE SUMMARY



Modbus Detection Lab
10/12/2026
siage

Disclaimer

The analysis, data, and reports in CSET® are provided “as is” for informational purposes only. The Cybersecurity & Infrastructure Security Agency (CISA) does not provide any warranties of any kind regarding any information contained within. In no event shall the United States Government or its contractors or subcontractors be liable for any damages, including but not limited to, direct, indirect, special, or consequential damages and including damages based on any negligence of the United States Government or its contractors or subcontractors, arising out of, resulting from, or in any way connected with this report, whether based on warranty, contract, tort, or otherwise, whether injury was sustained from, or arose out of the results of, or reliance upon the report.

CISA does not endorse any commercial product or service, including the subject of the assessment or evaluation in this report. Any reference to specific commercial products, processes, or services by trademark, manufacturer, or otherwise, does not constitute or imply its endorsement, recommendation, or favoring by CISA.

The display of the CISA official seal or other CISA visual identities on this report shall not be interpreted to provide the recipient organization authorization to use the official seal, insignia or other visual identities of CISA. The CISA seal, insignia, or other visual identities shall not be used in any manner to imply endorsement of any commercial product or activity by CISA or the United States Government. Use of the CISA seal without proper authorization violates federal law (e.g., 18 U.S.C. §§ 506, 701, 1017), and is against CISA policies governing usage of the seal.

The report is prepared and intended for internal use by the organization that made the request. The contents of this report may be subject to government or private intellectual property rights. To request distribution of this report outside the organization for which it was prepared, contact the CSET Program Office. The contents of this report may be reproduced or incorporated into other reports, but may not be modified without the prior express written permission of the CSET Program Office.

Advisory

The Cyber Security Evaluation Tool (CSET®) is only one component of the overall cybersecurity picture and should be complemented with a robust cyber security program within the organization. A self-assessment with CSET® cannot reveal all types of security weaknesses, and should not be the sole means of determining an organization's security posture.

The tool will not provide a detailed architectural analysis of the network or a detailed network hardware/software configuration review. It is not a risk analysis tool so it will not generate a complex risk assessment. CSET® is not intended as a substitute for in-depth analysis of control system vulnerabilities as performed by trained professionals. Periodic onsite reviews and inspections must still be conducted using a holistic approach including facility walk-downs, interviews, and observation and examination of facility practices. Consideration should also be given to additional steps including scanning, penetration testing, and exercises on surrogate, training, or non-production systems, or systems where failures, unexpected faults, or other unexpected results will not compromise production or safety.

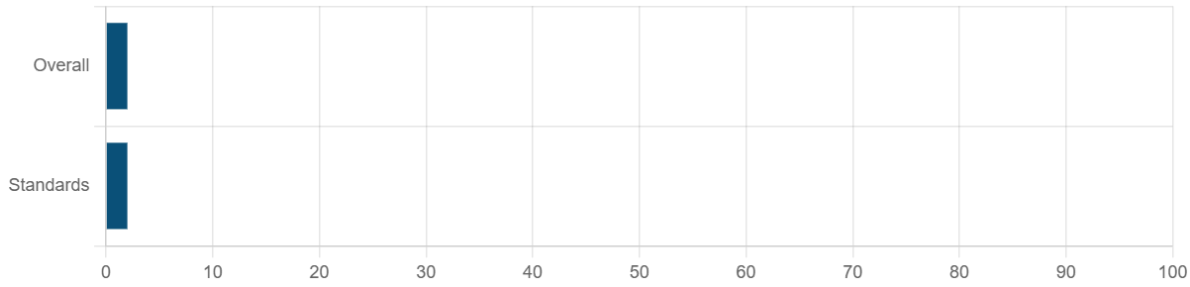
CSET® assessments cannot be completed effectively by any one individual. A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential. The representatives must be subject matter experts with significant expertise in their respective areas. No one individual has the span of responsibility or knowledge to effectively answer all the questions.

Data and reports generated by the tool should be managed securely and marked, stored, and distributed in a manner appropriate to their sensitivity.

Site Information

Assessment Name	Modbus Detection Lab
Assessment Date	10/12/2026
Facility Name	
City or Site Name	
State, Province, or Region	
Principal Assessor Name	
Additional Notes and Comments	
Contacts	

Summary Percent Compliance

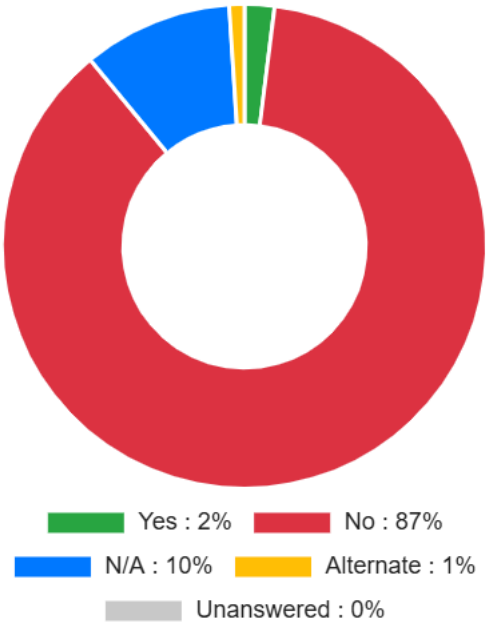


Executive Summary

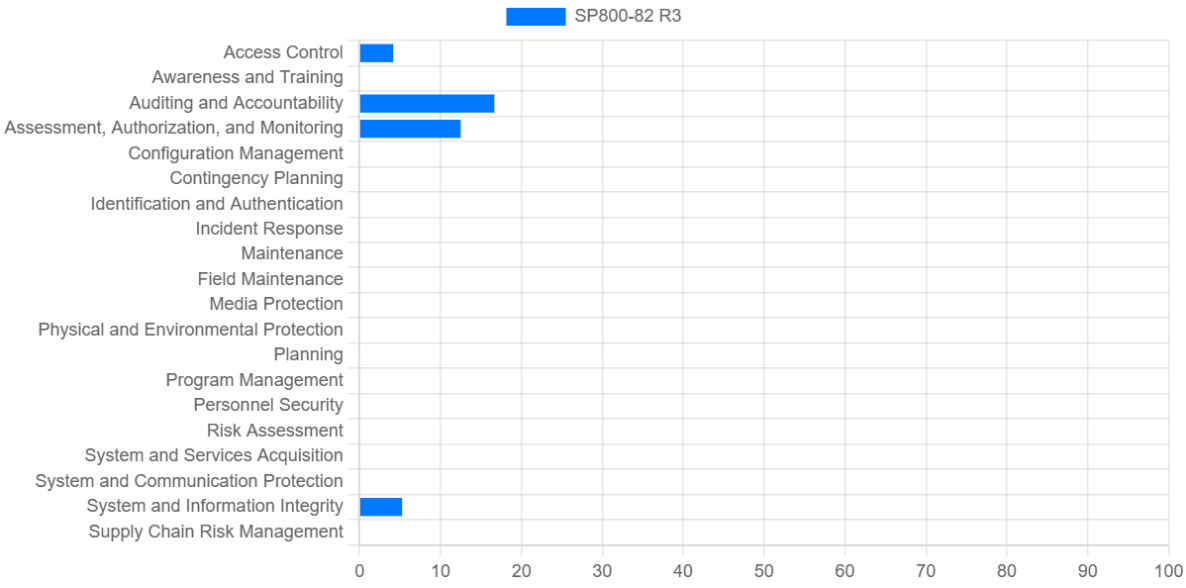
Cyber terrorism is a real and growing threat. Standards and guides have been developed, vetted, and widely accepted to assist with protection from cyber attacks. The Cyber Security Evaluation Tool (CSET) includes a selectable array of these standards for a tailored assessment of cyber vulnerabilities. Once the standards were selected and the resulting question sets answered, the CSET created a compliance summary, compiled variance statistics, ranked top areas of concern, and generated security recommendations.

Evaluation Against Selected Standards and Question Sets

Standards Summary

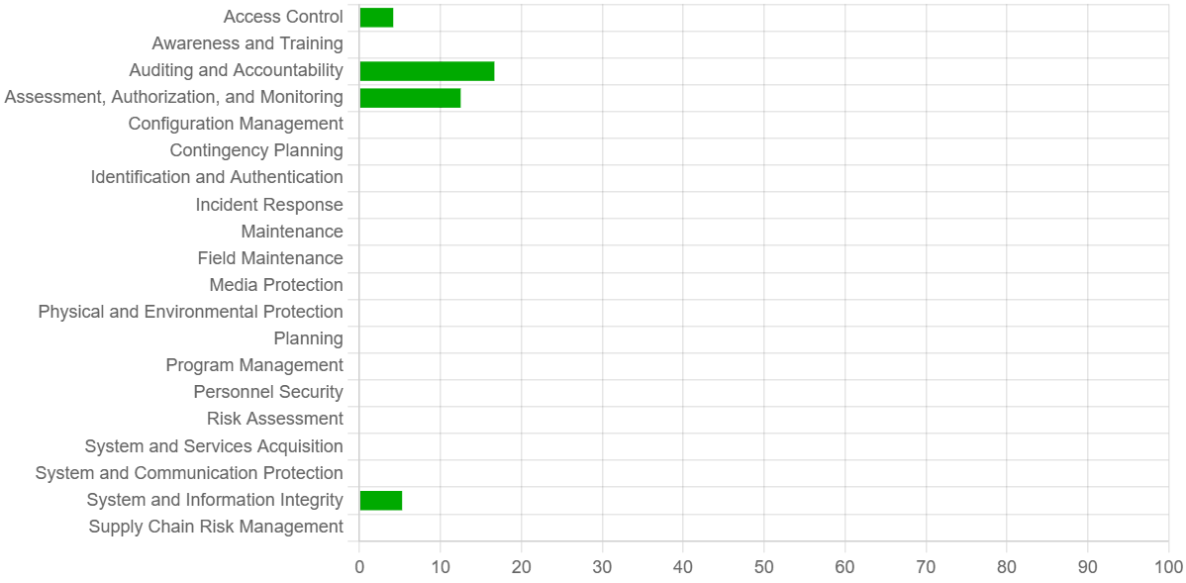


Standard or Question Set



Standards Compliance

SP800-82 R3



Security Assurance Level (SAL)



	Confidentiality	Integrity	Availability
Overall Values	High	High	High

FIPS 199 Security Assurance Level Guidance

NIST SP800-60 (FIPS 199) Based Security Assurance Levels with CNSS Special Factors

	Confidentiality	Integrity	Availability
Adjusted For System Questions	High	High	High
Information Type	Low	Low	Low

Type	Special Factors
Confidentiality	
Integrity	
Availability	

Document Library

Title	File Name
	There are no documents to display

Ranked Categories

Ranking information cannot be determined for the current question set. The Ranked Categories chart cannot be displayed.

Summary of Ranked Questions

Each question that did not meet the required Security Assurance Level (SAL) is shown in ranking order below. The displayed levels are the SALs applicable to that question. They are: Low (L), Moderate (M), High (H), and Very High (VH). CNSSI levels are for Confidentiality (C), Integrity (I), and Availability (A). DoD Instruction 8500.2 levels are for Confidentiality (Conf) and Mission Assurance Category (MAC). They are: Classified (C), Sensitive (S), and Public (P) for Confidentiality; MAC I, II, and III for Mission Assurance Category.

Rank: 1	Access Control #AC-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. OT access by vendors and maintenance staff can occur over a large facility footprint or geographic area and into unobserved spaces, such as mechanical or electrical rooms, ceilings, floors, field substations, switch and valve vaults, and pump stations. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System level*] access control policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and update the current access control: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System level*] access control policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and update the current access control: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-*	No

defined frequency] and following [*Assignment: organization-defined events*].	

Rank: 2	Access Control #AC-2	Level: High
OT Discussion: In OT systems, physical security, personnel security, intrusion detection, or auditing measures may support this control objective. a. Define and document the types of accounts allowed and specifically prohibited for use within the system; b. Assign account managers; c. Require [*Assignment: organization-defined prerequisites and criteria*] for group and role membership; d. Specify: 1. Authorized users of the system; 2. Group and role membership; and 3. Access authorizations (i.e., privileges) and [*Assignment: organization-defined attributes (as required)*] for each account; e. Require approvals by [*Assignment: organization-defined personnel or roles*] for requests to create accounts; f. Create, enable, modify, disable, and remove accounts in accordance with [*Assignment: organization-defined policy, procedures, prerequisites, and criteria*]; g. Monitor the use of accounts; h. Notify account managers and [*Assignment: organization-defined personnel or roles*] within: 1. [*Assignment: organization-defined time period*] when accounts are no longer required; 2. [*Assignment: organization-defined time period*] when users are terminated or transferred; and 3. [*Assignment: organization-defined time period*] when system usage or need-to-know changes for an individual; i. Authorize access to the system based on: 1. A valid access authorization; 2. Intended system usage; and 3. [*Assignment: organization-defined attributes (as required)*]; j. Review accounts for compliance with account management requirements [*Assignment: organization-defined frequency*]; k. Establish and implement a process for changing shared or group account authenticators (if deployed) when individuals are removed from the group; and l. Align account management processes with personnel termination and transfer processes.		No

Rank: 3	Access Control #AC-2 (13)	Level: High
OT Discussion: Close coordination occurs between OT, HR, IT, and physical security personnel to ensure the timely removal of high-risk individuals. Disable accounts of individuals within [*Assignment: organization-defined time period*] of discovery of [*Assignment: organization-defined significant risks*].		No

Rank: 4	Access Control #AC-3	Level: High
OT Discussion: The organization ensures that access enforcement mechanisms do not adversely impact the operational performance of the OT. Example compensating controls include encapsulation. The policy for logical access control to non-addressable and non-routable system resources and the associated information is made explicit. Access control mechanisms include hardware, firmware, and software that control the device or have device access, such as device drivers and communications controllers. Physical access control may serve as a compensating control for logical access control. However, it may not provide sufficient granularity when users require access to different functions. Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.		No

Rank: 5	Access Control #AC-6	Level: High

OT Discussion: Example compensating controls include providing increased personnel security and auditing. The organization carefully considers the appropriateness of a single individual having multiple critical privileges. System privilege models may be tailored to enforce integrity and availability (e.g., lower privileges include read access, and higher privileges include write access). Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks.	No

Rank: 6	Access Control #AC-6 (1)	Level: High
Least Privilege | Authorize Access to Security Functions OT Discussion: When OT components (e.g., PLCs) cannot support the logging of privileged functions, other system components within the authorization boundary may be used (e.g., engineering workstations or physical access monitoring). Authorize access for [*Assignment: organization-defined individuals or roles*] to: (a) [*Assignment: organization-defined security functions (deployed in hardware, software, and firmware)*]; and (b) [*Assignment: organization-defined security-relevant information*].		No

Rank: 7	Access Control #AC-6 (2)	Level: High

Least Privilege | Non-privileged Access for Nonsecurity Functions OT Discussion: When OT components (e.g., PLCs) cannot support the logging of privileged functions, other system components within the authorization boundary may be used (e.g., engineering workstations or physical access monitoring). Require that users of system accounts (or roles) with access to [*Assignment: organization-defined security functions or security-relevant information*] use non-privileged accounts or roles, when accessing nonsecurity functions.	No

Rank: 8	Access Control #AC-6 (3)	Level: High
Least Privilege | Network Access to Privileged Commands OT Discussion: When OT components (e.g., PLCs) cannot support the logging of privileged functions, other system components within the authorization boundary may be used (e.g., engineering workstations or physical access monitoring). Authorize network access to [*Assignment: organization-defined privileged commands*] only for [*Assignment: organization-defined compelling operational needs*] and document the rationale for such access in the security plan for the system.		No

Rank: 9	Access Control #AC-6 (5)	Level: High
Least Privilege | Privileged Accounts OT Discussion: When OT components (e.g., PLCs) cannot support the logging of privileged functions, other system components within the authorization boundary may be used (e.g., engineering workstations or physical access monitoring). Restrict privileged accounts on the system to [*Assignment: organization-defined personnel or roles*].		No

Rank: 10	Access Control #AC-6 (9)	Level: High
Least Privilege | Log Use of Privileged Functions OT Discussion: When OT components (e.g., PLCs) cannot support the logging of privileged functions, other system components within the authorization boundary may be used (e.g., engineering workstations or physical access monitoring). Log the execution of privileged functions.		No

Rank: 11	Access Control #AC-6 (10)	Level: High
Least Privilege | Prohibit Non-privileged Users from Executing Privileged Functions OT Discussion: Example compensating controls include enhanced auditing. Prevent non-privileged users from executing privileged functions.		No

Rank: 12	Access Control #AC-7	Level: High

OT Discussion: Many OT systems remain in continuous operation, and operators remain logged onto the system at all times. A “log-over” capability may be employed. Example compensating controls include logging or recording all unsuccessful logon attempts and alerting OT security personnel through alarms or other means when the number of organization-defined consecutive invalid access attempts is exceeded. Unsuccessful logon attempt limits are enforced for accounts (e.g., administrator) or systems (e.g., engineering workstations) that are not required for continuous operation. a. Enforce a limit of [*Assignment: organization-defined number*] consecutive invalid logon attempts by a user during a [*Assignment: organization-defined time period*]; and b. Automatically [Selection (one or more): lock the account or node for an [Assignment: organization-defined time period]; lock the account or node until released by an administrator; delay next logon prompt per [Assignment: organization-defined delay algorithm]; notify system administrator; take other [Assignment: organization-defined action]] when the maximum number of unsuccessful attempts is exceeded.	No

Rank: 13	Access Control #AC-11	Level: High

OT Discussion: This control assumes a staffed environment where users interact with system displays. This control may be tailored appropriately where systems do not have displays configured, systems are placed in an access-controlled facility or locked enclosure, or immediate operator response is required in emergency situations. Example compensating controls include locating the display in an area with physical access controls that limit access to individuals with permission and need-to-know for the displayed information. a. Prevent further access to the system by [Selection (one or more): initiating a device lock after [Assignment: organization-defined time period] of inactivity; requiring the user to initiate a device lock before leaving the system unattended]; and b. Retain the device lock until the user reestablishes access using established identification and authentication procedures.	No

Rank: 14	Access Control #AC-11 (1)	Level: High
Device Lock | Pattern-hiding Displays OT Discussion: Physical protection may be employed to prevent access to a display or the attachment of a display. When the OT cannot conceal displayed information, the organization employs nonautomated mechanisms or procedures as compensating controls in accordance with the general tailoring guidance. Conceal, via the device lock, information previously visible on the display with a publicly viewable image.		No

Rank: 15	Access Control #AC-12	Level: High
OT Discussion: Example compensating controls include providing increased auditing measures or limiting remote access privileges to key personnel. Automatically terminate a user session after [*Assignment: organization-defined conditions or trigger events requiring session disconnect*].		No

Rank: 16	Access Control #AC-17	Level: High
OT Discussion: When the OT cannot implement any or all of the components of this control, the organization employs other mechanisms or procedures as compensating controls in accordance with the general tailoring guidance. a. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed; and b. Authorize each type of remote access to the system prior to allowing such connections.		No

Rank: 17	Access Control #AC-17 (1)	Level: High
Remote Access | Monitoring and Control OT Discussion: Example compensating controls include employing nonautomated mechanisms or procedures as compensating controls. Compensating controls could include limiting remote access to a specified period of time or placing a call from the OT site to the authenticated remote entity. Employ automated mechanisms to monitor and control remote access methods.		No

Rank: 18	Access Control #AC-17 (2)	Level: High

Remote Access | Protection of Confidentiality and Integrity Using Encryption OT Discussion: Encryption-based technologies should be used to support the confidentiality and integrity of remote access sessions. While OT devices often lack the ability to support modern encryption, additional devices (e.g., VPNs) can be added to support these features. This control should not be confused with SC-8 – Transmission Confidentiality and Integrity, which discusses confidentiality and integrity requirements for general communications, including between OT devices. Implement cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions.	No

Rank: 19	Access Control #AC-17 (3)	Level: High
Remote Access | Managed Access Control Points OT Discussion: Example compensating controls include connection□specific manual authentication of the remote entity. Route remote accesses through authorized and managed network access control points.		No

Rank: 20	Access Control #AC-17 (10)	Level: High
Remote Access | Authenticate Remote Commands Rationale for adding AC-17 (10) to MOD and HIGH baselines: The ability to authenticate remote commands is important to prevent unauthorized commands that may have immediate or serious consequences, such as injury, death, property damage, the loss of high-value assets, the failure of mission or business functions, or compromise of sensitive information. Implement [*Assignment: organization-defined mechanisms*] to authenticate [*Assignment: organization-defined remote commands*].		No

Rank: 21	Access Control #AC-18	Level: High
OT Discussion: When OT cannot implement any or all of the components of this control, the organization employs other mechanisms or procedures as compensating controls in accordance with the general tailoring guidance. a. Establish configuration requirements, connection requirements, and implementation guidance for each type of wireless access; and b. Authorize each type of wireless access to the system prior to allowing such connections.		No

Rank: 22	Access Control #AC-18 (1)	Level: High
Wireless Access | Authentication and Encryption OT Discussion: The implementation of authentication and encryption is driven by the OT environment. If devices and users cannot all be authenticated and encrypted due to operational or technology constraints, compensating controls include providing increased auditing for wireless access, limiting wireless access privileges to key personnel, or using AC-18 (5) to reduce the boundary of wireless access. Protect wireless access to the system using authentication of [*Selection (one or more): users; devices*] and encryption.		No

Rank: 23	Access Control #AC-20	Level: High

OT Discussion: Organizations refine the definition of “external” to reflect lines of authority and responsibility, the granularity of an organization entity, and their relationships. An organization may consider a system to be external if that system performs different functions, implements different policies, falls under different management authorities, or does not provide sufficient visibility into the implementation of controls to allow the establishment of a satisfactory trust relationship. For example, an OT system and a business data processing system may be considered external to each other depending on the organization’s system boundaries. Access to an OT for support by a business partner, such as a vendor or support contractor, is another common example. The definition and trustworthiness of external systems is reexamined with respect to OT functions, purposes, technology, and limitations to establish a clearly documented technical or business case for use and an acceptance of the risk inherent in the use of an external system. a. [Selection (one or more): Establish [Assignment: organization-defined terms and conditions]; Identify [Assignment: organization-defined controls asserted to be implemented on external systems]], consistent with the trust relationships established with other organizations owning, operating, and/or maintaining external systems, allowing authorized individuals to: 1. Access the system from external systems; and 2. Process, store, or transmit organization-controlled information using external systems; or b. Prohibit the use of [*Assignment: organizationally-defined types of external systems*].	No

Rank: 24	Awareness and Training #AT-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] awareness and training policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the awareness and training policy and the associated awareness and training controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the awareness and training policy and procedures; and c. Review and update the current awareness and training: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 25	Awareness and Training #AT-2	Level: High

OT Discussion: Security awareness training includes initial and periodic review of OT-specific policies, standard operating procedures, security trends, and vulnerabilities. The OT security awareness program is consistent with the requirements of the security awareness and training policy established by the organization. a. Provide security and privacy literacy training to system users (including managers, senior executives, and contractors): 1. As part of initial training for new users and [*Assignment: organization-defined frequency*] thereafter; and 2. When required by system changes or following [*Assignment: organization-defined events*]; b. Employ the following techniques to increase the security and privacy awareness of system users [*Assignment: organization-defined awareness techniques*]; c. Update literacy training and awareness content [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and d. Incorporate lessons learned from internal or external security incidents or breaches into literacy training and awareness techniques.	No

Rank: 26	Awareness and Training #AT-2 (4)	Level: High

Literacy Training and Awareness | Suspicious Communications and Anomalous System Behavior OT Discussion: Identify and communicate suspicious and anomalous behaviors within the OT environment. Some examples of OT suspicious or anomalous behavior may include a PLC still in programming mode when it is expected to be in run mode, process trips with an undetermined root cause, malware on an HMI, unexpected mouse movement, or process changes that are not being performed by the operator. Rationale for adding AT-2 (4) to MOD and HIGH baselines: Training OT personnel on potentially suspicious communications and anomalous behaviors as well as the actions to take if anomalous system behavior occurs can supplement system detection and protection mechanisms for improved response. Provide literacy training on recognizing suspicious communications and anomalous behavior in organizational systems using [*Assignment: organization-defined indicators of malicious code*].	No

Rank: 27	Awareness and Training #AT-3	Level: High

OT Discussion: Security training includes initial and periodic review of OT-specific policies, standard operating procedures, security trends, and vulnerabilities. The OT security training program is consistent with the requirements of the security awareness and training policy established by the organization. The training may be customized for specific OT roles, which could include operators, maintainers, engineers, supervisors, and administrators. a. Provide role-based security and privacy training to personnel with the following roles and responsibilities: [*Assignment: organization-defined roles and responsibilities*]: 1. Before authorizing access to the system, information, or performing assigned duties, and [*Assignment: organization-defined frequency*] thereafter; and 2. When required by system changes; b. Update role-based training content [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and c. Incorporate lessons learned from internal or external security incidents or breaches into role-based training.	No

Rank: 28	Auditing and Accountability #AU-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] audit and accountability policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the audit and accountability policy and the associated audit and accountability controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the audit and accountability policy and procedures; and c. Review and update the current audit and accountability: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 29	Auditing and Accountability #AU-8	Level: High
OT Discussion: Example compensating controls include using a separate system designated as an authoritative time source. See related control SC-45. a. Use internal system clocks to generate time stamps for audit records; and b. Record time stamps for audit records that meet [*Assignment: organization-defined granularity of time measurement*] and that use Coordinated Universal Time, have a fixed local time offset from Coordinated Universal Time, or that include the local time offset as part of the time stamp.		No

Rank: 30	Auditing and Accountability #AU-10	Level: High

OT Discussion: OT devices may not enforce non-repudiation of audit records and may require compensating controls. Example compensating controls include physical security systems, cameras to monitor user access, or a separate device for log collection. Provide irrefutable evidence that an individual (or process acting on behalf of an individual) has performed [*Assignment: organization-defined actions to be covered by non-repudiation*].	No

Rank: 31	Auditing and Accountability #AU-12 (1)	Level: High
Audit Record Generation | System-wide and Time-correlated Audit Trail OT Discussion: Example compensating controls include providing time-correlated audit records on a separate system. Compile audit records from [*Assignment: organization-defined system components*] into a system-wide (logical or physical) audit trail that is time-correlated to within [*Assignment: organization-defined level of tolerance for the relationship between time stamps of individual records in the audit trail*].		No

Rank: 32	Auditing and Accountability #AU-12 (3)	Level: High
Audit Record Generation | Changes by Authorized Individuals OT Discussion: Example compensating controls include employing nonautomated mechanisms or procedures. Provide and implement the capability for [*Assignment: organization-defined individuals or roles*] to change the logging to be performed on [*Assignment: organization-defined system components*] based on [*Assignment: organization-defined selectable event criteria*] within [*Assignment: organization-defined time thresholds*].		No

Rank: 33	Assessment, Authorization, and Monitoring #CA-1	Level: High
OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] assessment, authorization, and monitoring policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the assessment, authorization, and monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the assessment, authorization, and monitoring policy and procedures; and c. Review and update the current assessment, authorization, and monitoring: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].		No

Rank: 34	Assessment, Authorization, and Monitoring #CA-2	Level: High

OT Discussion: Assessments are performed and documented by qualified assessors (i.e., experienced in assessing OT) authorized by the organization. The individual or group conducting the assessment fully understands the organizational information security policies and procedures, the OT security policies and procedures, and the specific health, safety, and environmental risks associated with a particular facility and/or process. The organization ensures that the assessment does not affect system operation or result in unintentional system modification. If assessment activities must be performed on the production OT, it may need to be taken offline before an assessment can be conducted, or the assessment should be scheduled to occur during planned OT outages whenever possible. a. Select the appropriate assessor or assessment team for the type of assessment to be conducted; b. Develop a control assessment plan that describes the scope of the assessment including: 1. Controls and control enhancements under assessment; 2. Assessment procedures to be used to determine control effectiveness; and 3. Assessment environment, assessment team, and assessment roles and responsibilities; c. Ensure the control assessment plan is reviewed and approved by the authorizing official or designated representative prior to conducting the assessment; d. Assess the controls in the system and its environment of operation [*Assignment: organization-defined frequency*] to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting established security and privacy requirements; e. Produce a control assessment report that document the results of the assessment; and f. Provide the results of the control assessment to [*Assignment: organization-defined individuals or roles*].	No

Rank: 35	Assessment, Authorization, and Monitoring #CA-3	Level: High

OT Discussion: Organizations perform risk-benefit analysis to determine whether an OT should be connected to other systems. The authorizing official (AO) fully understands the organizational information security policies and procedures; the OT security policies and procedures; the risks to organizational operations and assets, individuals, other organizations, and the Nation associated with the connection to other systems; the individuals and organizations that operate and maintain the systems, including maintenance contractors or service providers; and the specific health, safety, and environmental risks associated with a particular interconnection. Connections from the OT environment to other security zones may cross the authorization boundary such that two different authorizing officials may be required to approve the connection. Decisions to accept risk are documented. a. Approve and manage the exchange of information between the system and other systems using [Selection (one or more): interconnection security agreements; information exchange security agreements; memoranda of understanding or agreement; service level agreements; user agreements; nondisclosure agreements; [Assignment: organization-defined type of agreement]]; b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and c. Review and update the agreements [*Assignment: organization-defined frequency*].	No

Rank: 36	Assessment, Authorization, and Monitoring #CA-5	Level: High

OT Discussion: Corrective actions identified in assessments may not be immediately actionable in an OT environment. Therefore, short-term mitigations may be implemented to reduce risk as part of the gap closure plan or plan of action and milestones. a. Develop a plan of action and milestones for the system to document the planned remediation actions of the organization to correct weaknesses or deficiencies noted during the assessment of the controls and to reduce or eliminate known vulnerabilities in the system; and b. Update existing plan of action and milestones [*Assignment: organization-defined frequency*] based on the findings from control assessments, independent audits or reviews, and continuous monitoring activities.		No

Rank: 37	Assessment, Authorization, and Monitoring #CA-8	Level: High
OT Discussion: Penetration testing is used with care on OT networks to ensure that OT functions are not adversely impacted by the testing process. In general, OT systems are highly sensitive to timing constraints and have limited resources. Example compensating controls include employing a replicated, virtualized, or simulated system to conduct penetration testing. Production OT may need to be taken offline before testing can be conducted. If OT systems are taken offline for testing, tests are scheduled to occur during planned OT outages whenever possible. If penetration testing is performed on non-OT networks, extra care is taken to ensure that tests do not propagate into the OT network. Conduct penetration testing [*Assignment: organization-defined frequency*] on [*Assignment: organization-defined systems or system components*].		No

Rank: 38	Assessment, Authorization, and Monitoring #CA-8 (1)	Level: High

Penetration Testing | Independent Penetration Testing Agent or Team Rationale for removing CA-8 (1) from HIGH baseline: Specific expertise is necessary to conduct effective penetration testing on OT systems, and it may not be feasible to identify independent personnel with the appropriate skillset or knowledge to perform penetration testing on an OT environment. While an independent penetration test agent or team is recommended, it may not be feasible for all high-impact OT systems. Employ an independent penetration testing agent or team to perform penetration testing on the system or system components.	No

Rank: 39	Assessment, Authorization, and Monitoring #CA-9	Level: High
OT Discussion: Organizations perform risk-benefit analysis to determine whether OT equipment should be connected to other internal system components and then document those connections. The AO fully understands the potential risks associated with approving individual connections or approving a class of components to be connected. For example, the AO may broadly approve the connection of any sensors limited to 4 to 20 milliamp (mA) communication, while other connection types (e.g., serial or Ethernet) require individual approval. Decisions to accept risk are documented. a. Authorize internal connections of [*Assignment: organization-defined system components or classes of components*] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [*Assignment: organization-defined conditions*]; and d. Review [*Assignment: organization-defined frequency*] the continued need for each internal connection.		No

Rank: 40	Configuration Management #CM-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] configuration management policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the configuration management policy and procedures; and c. Review and update the current configuration management: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 41	Configuration Management #CM-3	Level: High

OT Discussion: Configuration change control procedures should align with the organization's management of change practices. a. Determine and document the types of changes to the system that are configuration-controlled; b. Review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analyses; c. Document configuration change decisions associated with the system; d. Implement approved configuration-controlled changes to the system; e. Retain records of configuration-controlled changes to the system for [*Assignment: organization-defined time period*]; f. Monitor and review activities associated with configuration-controlled changes to the system; and g. Coordinate and provide oversight for configuration change control activities through [*Assignment: organization-defined configuration change control element*] that convenes [Selection (one or more): [Assignment: organization-defined frequency]; when [Assignment: organization-defined configuration change conditions]].	No

Rank: 42	Configuration Management #CM-3 (7)	Level: High
Configuration Change Control | Review System Changes OT Discussion: The organization considers OT-specific requirements when determining the frequency and/or circumstances for reviewing system changes. For example, safety instrumented systems may be justified for the review of system changes on a predetermined frequency to ensure that no inadvertent changes have been made to the logic solver portion of a safety instrumented function. Review changes to the system [*Assignment: organization-defined frequency*] or when [*Assignment: organization-defined circumstances*] to determine whether unauthorized changes have occurred.		No

Rank: 43	Configuration Management #CM-3 (8)	Level: High

Configuration Change Control | Prevent or Restrict Configuration Changes OT Discussion: The organization prevents or restricts configuration changes based on a risk determination that the system should not be modified without additional permission. For example, some PLCs have physical key switches that are used to place the PLC in a mode that allows for programming changes. Physical key switches can restrict configuration changes so that physical access is required to make a modification to the system. Prevent or restrict changes to the configuration of the system under the following circumstances: [*Assignment: organization-defined circumstances*].	No

Rank: 44	Configuration Management #CM-4	Level: High
OT Discussion: The organization considers OT safety and security interdependencies. OT security and safety personnel are included in change process management if the change to the system may impact safety or security. Analyze changes to the system to determine potential security and privacy impacts prior to change implementation.		No

Rank: 45	Configuration Management #CM-5	Level: High
OT Discussion: Some OT devices allow for the configuration and use of mode change switches. Where available, these should be used to prevent unauthorized changes. For example, many PLCs have key switches that allow the device to be placed in a programming mode or a running mode. Those PLCs should be placed in a running or remote mode to prevent unauthorized programming changes, and the key should be removed from the key switch and managed appropriately. Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system.		No

Rank: 46	Configuration Management #CM-7	Level: High
OT Discussion: The organization implements least functionality by allowing only the specified functions, protocols, and/or services required for OT operations. For non-routable protocols, such as serial communications, interrupts could be disabled or set points could be made read□only except for privileged users to limit functionality. Ports are part of the address space in network protocols and are often associated with specific protocols or functions. For routable protocols, ports can be disabled on many networking devices to limit functionality to the minimum required for operation. a. Configure the system to provide only [*Assignment: organization-defined mission essential capabilities*]; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [*Assignment: organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services*].		No

Rank: 47	Configuration Management #CM-7 (5)	Level: High
Least Functionality | Authorized Software OT Discussion: The set of applications that run in OT is relatively static, making allowlisting practical. DHS recommends using application allowlisting for OT equipment. Unauthorized software programs can be limited to specific versions or from a specific source. The concept of prohibiting the execution of unauthorized software may also be applied to user actions, system ports and protocols, IP addresses/ranges, websites, and MAC addresses.		No

Rank: 48	Configuration Management #CM-9	Level: High

OT Discussion: Configuration management plans apply to the internal and external (e.g., contractors, integrators) resources responsible for device configuration. Develop, document, and implement a configuration management plan for the system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the system and places the configuration items under configuration management; d. Is reviewed and approved by [*Assignment: organization-defined personnel or roles*]; and e. Protects the configuration management plan from unauthorized disclosure and modification.	No

Rank: 49	Configuration Management #CM-12	Level: High
OT Discussion: Organizations identify specific information types or components to track where information is being processed and stored. Information to consider in the OT environment may include shared account passwords, PLC backup files, detailed network drawings, and risk assessments that identify specific threats with the environment. a. Identify and document the location of [*Assignment: organization-defined information*] and the specific system components on which the information is processed and stored; b. Identify and document the users who have access to the system and system components where the information is processed and stored; and c. Document changes to the location (i.e., system or system components) where the information is processed and stored.		No

Rank: 50	Contingency Planning #CP-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] contingency planning policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the contingency planning policy and the associated contingency planning controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the contingency planning policy and procedures; and c. Review and update the current contingency planning: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 51	Contingency Planning #CP-2	Level: High

OT Discussion: The organization defines contingency plans for categories of disruptions or failures. In the case of a contingency, the OT equipment executes preprogrammed functions, such as alerting the operator of the failure and then doing nothing, alerting the operator and then safely shutting down the industrial process, or alerting the operator and then maintaining the last operational setting prior to failure. Contingency plans for widespread disruption may involve specialized organizations (e.g., FEMA, emergency services, regulatory authorities). a. Develop a contingency plan for the system that: 1. Identifies essential mission and business functions and associated contingency requirements; 2. Provides recovery objectives, restoration priorities, and metrics; 3. Addresses contingency roles, responsibilities, assigned individuals with contact information; 4. Addresses maintaining essential mission and business functions despite a system disruption, compromise, or failure; 5. Addresses eventual, full system restoration without deterioration of the controls originally planned and implemented; 6. Addresses the sharing of contingency information; and 7. Is reviewed and approved by [*Assignment: organization-defined personnel or roles*]; b. Distribute copies of the contingency plan to [*Assignment: organization-defined key contingency personnel (identified by name and/or by role) and organizational elements*]; c. Coordinate contingency planning activities with incident handling activities; d. Review the contingency plan for the system [*Assignment: organization-defined frequency*]; e. Update the contingency plan to address changes to the organization, system, or environment of operation and problems encountered during contingency plan implementation, execution, or testing; f. Communicate contingency plan changes to [*Assignment: organization-defined key contingency personnel (identified by name and/or by role) and organizational elements*]; g. Incorporate lessons learned from contingency plan testing, training, or actual contingency activities into contingency testing and training; and h. Protect the contingency plan from unauthorized disclosure and modification.	No

Rank: 52	Contingency Planning #CP-4 (2)	Level: High
Contingency Plan Testing | Alternate Processing Site OT Discussion: Not all systems will have alternate processing sites, as discussed in CP-7. Test the contingency plan at the alternate processing site: (a) To familiarize contingency personnel with the facility and available resources; and (b) To evaluate the capabilities of the alternate processing site to support contingency operations.		No

Rank: 53	Contingency Planning #CP-7	Level: High
OT Discussion: Many site-wide supervisory or optimization servers (i.e., Level 3 and above of the Purdue model) can be supported from an alternate processing site. It is likely not feasible for control systems or field devices, such as sensors or final elements (i.e., Level 1 and 0 of the Purdue model), to be made available from an alternate processing site. a. Establish an alternate processing site, including necessary agreements to permit the transfer and resumption of [*Assignment: organization-defined system operations*] for essential mission and business functions within [*Assignment: organization-defined time period consistent with recovery time and recovery point objectives*] when the primary processing capabilities are unavailable; b. Make available at the alternate processing site, the equipment and supplies required to transfer and resume operations or put contracts in place to support delivery to the site within the organization-defined time period for transfer and resumption; and c. Provide controls at the alternate processing site that are equivalent to those at the primary site.		No

Rank: 54	Contingency Planning #CP-8	Level: High

OT Discussion: Quality of service factors for OT include latency and throughput. Establish alternate telecommunications services, including necessary agreements to permit the resumption of [*Assignment: organization-defined system operations*] for essential mission and business functions within [*Assignment: organization-defined time period*] when the primary telecommunications capabilities are unavailable at either the primary or alternate processing or storage sites.	No

Rank: 55	Contingency Planning #CP-8 (1)	Level: High
Telecommunications Services | Priority of Service Provisions OT Discussion: Testing for reliability and integrity increases confidence that the system can be restored after an incident and minimizes the impact associated with downtime and outages. The ability to test backups is often dependent on the resources needed to appropriately represent the environment, such as the availability of spare devices and testing equipment. Testing backup and restoration on OT is often limited to systems with redundancy or spare equipment. In certain cases, sampling will be limited to those redundant systems. Compensating controls may include alternative methods for testing backups, such as hash or checksum validations. (a) Develop primary and alternate telecommunications service agreements that contain priority-of-service provisions in accordance with availability requirements (including recovery time objectives); and (b) Request Telecommunications Service Priority for all telecommunications services used for national security emergency preparedness if the primary and/or alternate telecommunications services are provided by a common carrier.		No

Rank: 56	Contingency Planning #CP-8 (2)	Level: High

Telecommunications Services | Single Points of Failure OT Discussion: Testing for reliability and integrity increases confidence that the system can be restored after an incident and minimizes the impact associated with downtime and outages. The ability to test backups is often dependent on the resources needed to appropriately represent the environment, such as the availability of spare devices and testing equipment. Testing backup and restoration on OT is often limited to systems with redundancy or spare equipment. In certain cases, sampling will be limited to those redundant systems. Compensating controls may include alternative methods for testing backups, such as hash or checksum validations. Obtain alternate telecommunications services to reduce the likelihood of sharing a single point of failure with primary telecommunications services.	No

Rank: 57	Contingency Planning #CP-10	Level: High
OT Discussion: Reconstitution of the OT includes considering whether system state variables should be restored to initial values or the values before disruption (e.g., are valves restored to full open, full closed, or settings prior to disruption). Restoring system state variables may be disruptive to ongoing physical processes (e.g., valves initially closed may adversely affect system cooling). Provide for the recovery and reconstitution of the system to a known state within [*Assignment: organization-defined time period consistent with recovery time and recovery point objectives*] after a disruption, compromise, or failure.		No

Rank: 58	Contingency Planning #CP-10 (6)	Level: High

System Recovery and Reconstitution | Component Protection OT Discussion: Organizations should consider recovery and reconstitution timeframes when storing spare equipment, including environmental hazards that could damage the equipment. Storage locations and environments should be chosen appropriately for the type of backup equipment. Rationale for adding CP-10 (6) to MOD and HIGH baselines: OT system components stored without protection against environmental threats and unauthorized physical or logical access can be susceptible to compromise or damage. Certain system components may include embedded electronics that must be protected from environmental hazards. Protect system components used for recovery and reconstitution.	No

Rank: 59	Contingency Planning #CP-12	Level: High
Rationale for adding CP-12 to LOW, MOD, and HIGH baselines: This control provides a framework for the organization to plan its policy and procedures for dealing with IT and OT conditions beyond its control in the environment of operations to minimize potential safety and environmental impacts. When [*Assignment: organization-defined conditions*] are detected, enter a safe mode of operation with [*Assignment: organization-defined restrictions of safe mode of operation*].		No

Rank: 60	Identification and Authentication #IA-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] identification and authentication policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the identification and authentication policy and the associated identification and authentication controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the identification and authentication policy and procedures; and c. Review and update the current identification and authentication: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 61	Identification and Authentication #IA-2 (1)	Level: High
Identification and Authentication (organizational Users) | Multi-factor Authentication to Privileged Accounts OT Discussion: As a compensating control, physical access restrictions may sufficiently represent one authentication factor, provided that the system is not remotely accessible. Implement multi-factor authentication for access to privileged accounts.		No

Rank: 62	Identification and Authentication #IA-2 (2)	Level: High

Identification and Authentication (organizational Users) | Multi-factor Authentication to Non-privileged Accounts OT Discussion: As a compensating control, physical access restrictions may sufficiently represent one authentication factor, provided that the system is not remotely accessible. Implement multi-factor authentication for access to non-privileged accounts.	No

Rank: 63	Identification and Authentication #IA-2 (5)	Level: High
Identification and Authentication (organizational Users) | Individual Authentication with Group Authentication OT Discussion: For local access, physical access controls and logging may be used as an alternative to individual authentication on an OT system. For remote access, the remote access authentication mechanism will be used to identify, permit, and log individual access before permitting the use of shared accounts. When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources.		No

Rank: 64	Identification and Authentication #IA-3	Level: High

OT Discussion: OT devices may not inherently support device authentication. If devices are local to one another, physical security measures that prevent unauthorized communication between devices can be used as compensating controls. For remote communication, additional hardware may be required to meet authentication requirements. Rationale for adding IA-3 to LOW baseline: Given the variety of OT devices and physical locations of OT devices, organizations may consider whether OT devices that may be vulnerable to tampering or spoofing require unique identification and authentication and for what types of connections. Uniquely identify and authenticate [*Assignment: organization-defined devices and/or types of devices*] before establishing a [*Selection (one or more): local; remote; network*] connection.	No

Rank: 65	Identification and Authentication #IA-3 (1)	Level: High
Device Identification and Authentication | Cryptographic Bidirectional Authentication OT Discussion: For OT systems that include IIoT devices, these enhancements may be needed to protect device-to-device communication. Authenticate [*Assignment: organization-defined devices and/or types of devices*] before establishing [*Selection (one or more): local; remote; network*] connection using bidirectional authentication that is cryptographically based.		No

Rank: 66	Identification and Authentication #IA-3 (4)	Level: High

Device Identification and Authentication | Device Attestation OT Discussion: For OT systems that include IIoT devices, these enhancements may be needed to protect device-to-device communication. Handle device identification and authentication based on attestation by [*Assignment: organization-defined configuration management process*].	No

Rank: 67	Identification and Authentication #IA-4 (4)	Level: High
Identifier Management | Identify User Status OT Discussion: This control enhancement is typically implemented by the organization rather than at the system level. However, to manage risk for certain OT environments, identifiers (e.g., badges) may have different markings to indicate the status of individuals, such as contractors, foreign nationals, and non-organizational users. Manage individual identifiers by uniquely identifying each individual as [*Assignment: organization-defined characteristic identifying individual status*].		No

Rank: 68	Identification and Authentication #IA-5	Level: High

OT Discussion: Example compensating controls include physical access control and encapsulating the OT to provide authentication external to the OT. a. Verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, service, or device receiving the authenticator; b. Establishing initial authenticator content for any authenticators issued by the organization; c. Ensuring that authenticators have sufficient strength of mechanism for their intended use; d. Establishing and implementing administrative procedures for initial authenticator distribution, for lost or compromised or damaged authenticators, and for revoking authenticators; e. Changing default authenticators prior to first use; f. Changing or refreshing authenticators [*Assignment: organization-defined time period by authenticator type*] or when [*Assignment: organization-defined events*] occur; g. Protecting authenticator content from unauthorized disclosure and modification; h. Requiring individuals to take, and having devices implement, specific controls to protect authenticators; and i. Changing authenticators for group or role accounts when membership to those accounts changes.	No

Rank: 69	Identification and Authentication #IA-6	Level: High
OT Discussion: This control assumes a visual interface that provides feedback about authentication information during the authentication process. When OT authentication uses an interface that does not support visual feedback (e.g., protocol-based authentication), this control may be tailored out. Obscure feedback of authentication information during the authentication process to protect the information from possible exploitation and use by unauthorized individuals.		No

Rank: 70	Identification and Authentication #IA-8	Level: High

OT Discussion: The OT Discussion for IA-2, Identification and Authentication (Organizational Users) is applicable for non-organizational users. Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users.	No

Rank: 71	Identification and Authentication #IA-8 (1)	Level: High
Identification and Authentication (non-organizational Users) | Acceptance of PIV Credentials from Other Agencies OT Discussion: Acceptance of PIV credentials is only required for organizations that follow OMB Memorandum M-19-17 [OMB-M1917] (e.g., federal agencies and contractors). Accept and electronically verify Personal Identity Verification-compliant credentials from other federal agencies.		No

Rank: 72	Identification and Authentication #IA-8 (2)	Level: High
Identification and Authentication (non-organizational Users) | Acceptance of External Authenticators OT Discussion: Example compensating controls include implementing support external to the OT and multi-factor authentication. (a) Accept only external authenticators that are NIST-compliant; and (b) Document and maintain a list of accepted external authenticators.		No

Rank: 73	Identification and Authentication #IA-8 (4)	Level: High

Identification and Authentication (non-organizational Users) | Use of Defined Profiles OT Discussion: Example compensating controls include implementing support external to the OT and multi-factor authentication. Conform to the following profiles for identity management [*Assignment: organization-defined identity management profiles*].	No

Rank: 74	Identification and Authentication #IA-12	Level: High
OT Discussion: Identity proofing is likely performed by different departments within the organization. Existing organizational systems (e.g., HR or IT processes) should be leveraged to perform this control. a. Identity proof users that require accounts for logical access to systems based on appropriate identity assurance level requirements as specified in applicable standards and guidelines; b. Resolve user identities to a unique individual; and c. Collect, validate, and verify identity evidence.		No

Rank: 75	Identification and Authentication #IA-12 (1)	Level: High
Identity Proofing | Supervisor Authorization Control Enhancement: (1) OT Discussion: Maintenance, engineering, or third-party organizations may require OT access in order to support operations. The organization should determine the AO for proving identity prior to allowing access to the OT environment. Consider obtaining supervisor or sponsor authorization, where the sponsor may be someone within operations. Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization.		No

Rank: 76	Identification and Authentication #IA-12 (2)	Level: High
Identity Proofing | Identity Evidence OT Discussion: If the organization already performs these controls, existing organizational processes should be leveraged. For example, HR may provide a system for tracking identity evidence. OT does not need to develop an independent system for achieving this control. Require evidence of individual identification be presented to the registration authority.		No

Rank: 77	Identification and Authentication #IA-12 (3)	Level: High
Identity Proofing | Identity Evidence Validation and Verification OT Discussion: If the organization already performs these controls, existing organizational processes should be leveraged. For example, HR may provide a system for tracking identity evidence. OT does not need to develop an independent system for achieving this control. Require that the presented identity evidence be validated and verified through [*Assignment: organizational defined methods of validation and verification*].		No

Rank: 78	Identification and Authentication #IA-12 (4)	Level: High

Identity Proofing | In-person Validation and Verification OT Discussion: If the organization already performs these controls, existing organizational processes should be leveraged. For example, HR may provide a system for tracking identity evidence. OT does not need to develop an independent system for achieving this control. Require that the validation and verification of identity evidence be conducted in person before a designated registration authority.	No

Rank: 79	Identification and Authentication #IA-12 (5)	Level: High
Identity Proofing | Address Confirmation OT Discussion: If the organization already performs these controls, existing organizational processes should be leveraged. For example, HR may provide a system for tracking identity evidence. OT does not need to develop an independent system for achieving this control. Require that a [*Selection: registration code; notice of proofing*] be delivered through an out-of-band channel to verify the users address (physical or digital) of record.		No

Rank: 80	Incident Response #IR-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] incident response policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the incident response policy and the associated incident response controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the incident response policy and procedures; and c. Review and update the current incident response: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 81	Incident Response #IR-4	Level: High

OT Discussion: As part of the incident handling capability, the organization coordinates with external vendors, integrators, or suppliers as necessary to ensure that they have the capability to address events that are specific to embedded components and devices. a. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; b. Coordinate incident handling activities with contingency planning activities; c. Incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the resulting changes accordingly; and d. Ensure the rigor, intensity, scope, and results of incident handling activities are comparable and predictable across the organization.	No

Rank: 82	Incident Response #IR-6	Level: High
OT Discussion: The organization should report incidents on a timely basis. CISA collaborates with international and private-sector computer emergency response teams (CERTs) to share control systems-related security incidents and mitigation measures. a. Require personnel to report suspected incidents to the organizational incident response capability within [*Assignment: organization-defined time period*]; and b. Report incident information to [*Assignment: organization-defined authorities*].		No

Rank: 83	Incident Response #IR-6 (1)	Level: High
Incident Reporting | Automated Reporting OT Discussion: The automated mechanisms used to support the incident reporting process are not necessarily part of or connected to the OT. Report incidents using [*Assignment: organization-defined automated mechanisms*].		No

Rank: 84	Maintenance #MA-1	Level: High
OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. Control: a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] maintenance policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and update the current maintenance: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].		No

Rank: 85	Maintenance #MA-4 (1)	Level: High
Nonlocal Maintenance | Logging and Review Rationale for adding MA-4 (1) to MOD and HIGH baselines: OT environments are often heavily dependent on nonlocal maintenance providers, so organizations should have the ability to review logs about relevant maintenance activities. (a) Log [*Assignment: organization-defined audit events*] for nonlocal maintenance and diagnostic sessions; and (b) Review the audit records of the maintenance and diagnostic sessions to detect anomalous behavior.		No

Rank: 86	Maintenance #MA-4 (3)	Level: High
Nonlocal Maintenance | Comparable Security and Sanitization OT Discussion: The organization may need access to nonlocal maintenance and diagnostic services in order to restore essential OT operations or services. Example compensating controls include limiting the extent of the maintenance and diagnostic services to the minimum essential activities and carefully monitoring and auditing the nonlocal maintenance and diagnostic activities. (a) Require that nonlocal maintenance and diagnostic services be performed from a system that implements a security capability comparable to the capability implemented on the system being serviced; or (b) Remove the component to be serviced from the system prior to nonlocal maintenance or diagnostic services; sanitize the component (for organizational information); and after the service is performed, inspect and sanitize the component (for potentially malicious software) before reconnecting the component to the system.		No

Rank: 87	Field Maintenance #MA-7	Level: High

OT Discussion: Organizations identify OT systems and system components with specific calibration, maintenance, or other requirements and limit maintenance to specific facilities. Some examples may include safety-critical systems or systems involved in custody transfer where accuracy tolerances are limited and additional quality control checks are required. Rationale for adding MA-7 to LOW, MOD, and HIGH baselines: Some OT equipment have specific requirements for calibration, maintenance, and modification to meet regulatory or safety standards. Different deployed locations may impact the quality and precision of field maintenance. Restrict or prohibit field maintenance on [*Assignment: organization-defined systems or system components*] to [*Assignment: organization-defined trusted maintenance facilities*].	No

Rank: 88	Media Protection #MP-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. Control: a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] media protection policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the media protection policy and the associated media protection controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the media protection policy and procedures; and c. Review and update the current media protection: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 89	Physical and Environmental Protection #PE-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. The OT components can be distributed over a large facility footprint or geographic area and can be an entry point into the entire organizational network OT. Regulatory controls may also apply. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] physical and environmental protection policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the physical and environmental protection policy and the associated physical and environmental protection controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the physical and environmental protection policy and procedures; and c. Review and update the current physical and environmental protection: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 90	Physical and Environmental Protection #PE-3	Level: High

OT Discussion: The organization considers OT safety and security interdependencies and access requirements in emergency situations. During an emergency, the organization may restrict access to OT facilities and assets to authorized individuals only. OT systems are often constructed of devices that do not have or cannot use comprehensive access control capabilities due to time□restrictive safety constraints. Physical access controls and defense-in-depth measures are used by the organization when necessary and possible to supplement OT security when electronic mechanisms are unable to fulfill the security requirements of the organization's security plan. a. Enforce physical access authorizations at [*Assignment: organization-defined entry and exit points to the facility where the system resides*] by: 1. Verifying individual access authorizations before granting access to the facility; and 2. Controlling ingress and egress to the facility using [Selection (one or more): [Assignment: organization-defined physical access control systems or devices]; guards]; b. Maintain physical access audit logs for [*Assignment: organization-defined entry or exit points*]; c. Control access to areas within the facility designated as publicly accessible by implementing the following controls: [*Assignment: organization-defined physical access controls*]; d. Escort visitors and control visitor activity [*Assignment: organization-defined circumstances requiring visitor escorts and control of visitor activity*]; e. Secure keys, combinations, and other physical access devices; f. Inventory [*Assignment: organization-defined physical access devices*] every [*Assignment: organization-defined frequency*]; and g. Change combinations and keys [*Assignment: organization-defined frequency*] and/or when keys are lost, combinations are compromised, or when individuals possessing the keys or combinations are transferred or terminated.	No

Rank: 91	Physical and Environmental Protection #PE-6 (4)	Level: High

Monitoring Physical Access | Monitoring Physical Access to Systems Rationale for adding PE-6 (4) to MOD baseline: Many of the OT components are in remote geographical and dispersed locations. Other components may be in ceilings, floors, or distribution closets. Furthermore, physical access controls are frequently used as compensating controls when devices lack the ability to enforce logical access restrictions. Monitor physical access to the system in addition to the physical access monitoring of the facility at [*Assignment: organization-defined physical spaces containing one or more components of the system*].	No

Rank: 92	Physical and Environmental Protection #PE-10	Level: High
OT Discussion: It may not be possible or advisable to shut off power to some OT. The organizational-defined parameters for this control should be implemented in consultation with safety and operational personnel. Example compensating controls include failing to a known state and emergency procedures. a. Provide the capability of shutting off power to [*Assignment: organization-defined system or individual system components*] in emergency situations; b. Place emergency shutoff switches or devices in [*Assignment: organization-defined location by system or system component*] to facilitate access for authorized personnel; and c. Protect emergency power shutoff capability from unauthorized activation.		No

Rank: 93	Physical and Environmental Protection #PE-13	Level: High
OT Discussion: Fire suppression mechanisms should take the OT environment into account (e.g., water sprinkler systems could be hazardous in specific environments). Employ and maintain fire detection and suppression systems that are supported by an independent energy source.		No

Rank: 94	Physical and Environmental Protection #PE-21	Level: High
OT Discussion: Organizations that manage OT equipment may choose to utilize EMP protection to prevent adversarial or environmental electromagnetic threats. Organizations may select to follow National Coordinating Center for Communications (NCC) guidelines on EM pulse protection. Employ [*Assignment: organization-defined protective measures*] against electromagnetic pulse damage for [*Assignment: organization-defined systems and system components*].		No

Rank: 95	Physical and Environmental Protection #PE-22	Level: High
OT Discussion: Hardware components are marked or labeled to indicate information that is processed, stored, or transmitted. Component markings can be useful for differentiating between safety and control systems, OT and IT equipment, and internally and externally connected systems. Marking components reduces the probability of mismanaging the system or performing maintenance on an incorrect device. Rationale for adding PE-22 to MOD and HIGH baselines: OT is unique in that it may look like an IT component but perform a very different function. Visible differentiation between components that perform different functions can help reduce reliability incidents due to maintenance errors. Mark [*Assignment: organization-defined system hardware components*] indicating the impact level or classification level of the information permitted to be processed, stored, or transmitted by the hardware component.		No

Rank: 96	Planning #PL-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] planning policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the planning policy and the associated planning controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the planning policy and procedures; and c. Review and update the current planning: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 97	Planning #PL-2	Level: High

OT Discussion: When systems are highly interconnected, coordinated planning is essential. A low-impact system could adversely affect a higher-impact system. a. Develop security and privacy plans for the system that: 1. Are consistent with the organization’s enterprise architecture; 2. Explicitly define the constituent system components; 3. Describe the operational context of the system in terms of mission and business processes; 4. Identify the individuals that fulfill system roles and responsibilities; 5. Identify the information types processed, stored, and transmitted by the system; 6. Provide the security categorization of the system, including supporting rationale; 7. Describe any specific threats to the system that are of concern to the organization; 8. Provide the results of a privacy risk assessment for systems processing personally identifiable information; 9. Describe the operational environment for the system and any dependencies on or connections to other systems or system components; 10. Provide an overview of the security and privacy requirements for the system; 11. Identify any relevant control baselines or overlays, if applicable; 12. Describe the controls in place or planned for meeting the security and privacy requirements, including a rationale for any tailoring decisions; 13. Include risk determinations for security and privacy architecture and design decisions; 14. Include security- and privacy-related activities affecting the system that require planning and coordination with [Assignment: organization- defined individuals or groups]; and 15. Are reviewed and approved by the authorizing official or designated representative prior to plan implementation. b. Distribute copies of the plans and communicate subsequent changes to the plans to [*Assignment: organization-defined personnel or roles*]; c. Review the plans [*Assignment: organization-defined frequency*]; d. Update the plans to address changes to the system and environment of operation or problems identified during plan implementation or control assessments; and e. Protect the plans from unauthorized disclosure and modification.	No

Rank: 98	Planning #PL-7	Level: High
OT Discussion: Organizations need to consider documenting known operational procedures and exploring how they relate to the combination of IT and OT technologies within the environment. a. Develop a Concept of Operations (CONOPS) for the system describing how the organization intends to operate the system from the perspective of information security and privacy; and b. Review and update the CONOPS [*Assignment: organization-defined frequency*].		No

Rank: 99	Planning #PL-8 (1)	Level: High
Security and Privacy Architectures | Defense in Depth OT Discussion: Defense in depth is considered a common practice for security architecture within OT environments. Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [*Assignment: organization-defined controls*] to [*Assignment: organization-defined locations and architectural layers*]; and (b) Ensures that the allocated controls operate in a coordinated and mutually reinforcing manner.		No

Rank: 100	Planning #PL-9	Level: High
OT Discussion: If the architecture allows for it, consider centrally managing flaw remediation, malicious code protection, logging, and incident detection. Centrally manage [*Assignment: organization-defined controls and related processes*].		No

Rank: 101	Program Management #PM-8	Level: High

OT Discussion: Organizations should be familiar with the protection requirements and guidance defined by Executive Orders, government sector-specific agencies (SSAs), and industry trade organizations. Address information security and privacy issues in the development, documentation, and updating of a critical infrastructure and key resources protection plan.	No

Rank: 102	Program Management #PM-15	Level: High
OT Discussion: Organizations should be familiar with relevant security-focused and industry□specific groups or associations, including government sector-specific agencies (SSAs), Information Sharing and Analysis Centers (ISACs), and industry trade organizations. Establish and institutionalize contact with selected groups and associations within the security and privacy communities: a. To facilitate ongoing security and privacy education and training for organizational personnel; b. To maintain currency with recommended security and privacy practices, techniques, and technologies; and c. To share current security and privacy information, including threats, vulnerabilities, and incidents.		No

Rank: 103	Program Management #PM-16	Level: High
OT Discussion: The organization should collaborate and share information about potential incidents on a timely basis. CISA serves as a centralized location where operational elements involved in cybersecurity and communications reliance are coordinated and integrated. Organizations should consider having both an unclassified and classified information sharing capability. Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence.		No

Rank: 104	Program Management #PM-17	Level: High
OT Discussion: This control applies to federal agencies and other organizations that support the Government and process controlled unclassified information (CUI). a. Establish policy and procedures to ensure that requirements for the protection of controlled unclassified information that is processed, stored or transmitted on external systems, are implemented in accordance with applicable laws, executive orders, directives, policies, regulations, and standards; and b. Review and update the policy and procedures [*Assignment: organization-defined frequency*].		No

Rank: 105	Personnel Security #PS-1	Level: High
OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] personnel security policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the personnel security policy and the associated personnel security controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the personnel security policy and procedures; and c. Review and update the current personnel security: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].		No

Rank: 106	Personnel Security #PS-2	Level: High
OT Discussion: Private organizations should utilize existing sector-specific regulations, laws, policy, and guidance for determining appropriate risk designations for positions. a. Assign a risk designation to all organizational positions; b. Establish screening criteria for individuals filling those positions; and c. Review and update position risk designations [*Assignment: organization-defined frequency*].		No

Rank: 107	Risk Assessment #RA-1	Level: High
OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] risk assessment policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the risk assessment policy and the associated risk assessment controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the risk assessment policy and procedures; and c. Review and update the current risk assessment: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].		No

Rank: 108	Risk Assessment #RA-2	Level: High
OT Discussion: PHA, functional safety assessments, and other organization-established risk assessments can be referenced to identify the impact level of the OT systems. a. Categorize the system and information it processes, stores, and transmits; b. Document the security categorization results, including supporting rationale, in the security plan for the system; and c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision.		No

Rank: 109	Risk Assessment #RA-5	Level: High

OT Discussion: The organization makes a risk-based determination of how to monitor or scan for vulnerabilities on their system. This may include active scanning, passive monitoring, or compensating controls, depending on the system being scanned. For example, vulnerability examination may be performed using passive monitoring and manual visual inspection to maintain an up-to-date inventory of assets. That inventory can be cross-referenced against a list of known vulnerabilities (e.g., CISA advisories, NIST NVD). Production may need to be taken offline before active scans can be conducted. Scans are scheduled to occur during planned OT outages whenever possible. If vulnerability scanning tools are used on adjacent non-OT networks, extra care is taken to ensure that they do not mistakenly scan the OT network. Automated network scanning is not applicable to non-routable communications, such as serial networks. Compensating controls include providing a replicated or simulated system for conducting scans or host-based vulnerability applications. a. Monitor and scan for vulnerabilities in the system and hosted applications [*Assignment: organization-defined frequency and/or randomly in accordance with organization-defined process*] and when new vulnerabilities potentially affecting the system are identified and reported; b. Employ vulnerability monitoring tools and techniques that facilitate interoperability among tools and automate parts of the vulnerability management process by using standards for: 1. Enumerating platforms, software flaws, and improper configurations; 2. Formatting checklists and test procedures; and 3. Measuring vulnerability impact; c. Analyze vulnerability scan reports and results from vulnerability monitoring; d. Remediate legitimate vulnerabilities [*Assignment: organization-defined response times*] in accordance with an organizational assessment of risk; e. Share information obtained from the vulnerability monitoring process and control assessments with [*Assignment: organization-defined personnel or roles*] to help eliminate similar vulnerabilities in other systems; and f. Employ vulnerability monitoring tools that include the capability to readily update the vulnerabilities to be scanned.	No

Rank: 110	Risk Assessment #RA-5 (4)	Level: High
Vulnerability Monitoring and Scanning | Discoverable Information OT Discussion: Examples of discoverable information in OT could include information about key personnel or technical information related to systems and configurations. Locations that may need to be monitored or scanned include technical forums, blogs, and vendor or contractor websites. Determine information about the system that is discoverable and take [*Assignment: organization-defined corrective actions*].		No

Rank: 111	Risk Assessment #RA-5 (11)	Level: High
Vulnerability Monitoring and Scanning | Public Disclosure Program OT Discussion: For federal organizations, CISA Binding Operational Directive 20-01 requires individual federal civilian executive branch agencies to develop and publish a vulnerability disclosure policy (VDP) for their internet-accessible systems and services and maintain processes to support their VDP. A VDP may be implemented at the organization level rather than for each individual system. Federal and non-federal organizations could achieve this control by creating and monitoring an email address published on a public-facing website for contacting the organization regarding disclosures. Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components.		No

Rank: 112	System and Services Acquisition #SA-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] system and services acquisition policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the system and services acquisition policy and the associated system and services acquisition controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the system and services acquisition policy and procedures; and c. Review and update the current system and services acquisition: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 113	System and Services Acquisition #SA-3 (1)	Level: High
System Development Life Cycle | Manage Preproduction Environment OT Discussion: Organizations that do not maintain local pre□production environments and utilize a third-party integrator should ensure that contracts are developed to limit security and privacy risks. Protect system preproduction environments commensurate with risk throughout the system development life cycle for the system, system component, or system service.		No

Rank: 114	System and Services Acquisition #SA-3 (3)	Level: High

System Development Life Cycle | Technology Refresh OT Discussion: Many OT systems have an expected life cycle that is longer than most IT components. Technology refresh is addressed in budget planning to limit the use of obsolete systems that present security or reliability risks. Plan for and implement a technology refresh schedule for the system throughout the system development life cycle.	No

Rank: 115	System and Services Acquisition #SA-4	Level: High
OT Discussion: Organizations engage with OT suppliers to raise awareness of cybersecurity needs. The SCADA/Control Systems Procurement Project provides example cybersecurity procurement language for OT. Include the following requirements, descriptions, and criteria, explicitly or by reference, using [Selection (one or more): standardized contract language; [Assignment: organization-defined contract language]] in the acquisition contract for the system, system component, or system service: a. Security and privacy functional requirements; b. Strength of mechanism requirements; c. Security and privacy assurance requirements; d. Controls needed to satisfy the security and privacy requirements. e. Security and privacy documentation requirements; f. Requirements for protecting security and privacy documentation; g. Description of the system development environment and environment in which the system is intended to operate; h. Allocation of responsibility or identification of parties responsible for information security, privacy, and supply chain risk management; and i. Acceptance criteria.		No

Rank: 116	System and Services Acquisition #SA-4 (1)	Level: High

Acquisition Process | Functional Properties of Controls OT Discussion: When acquiring OT products, consideration for security requirements may not have been incorporated into the design. Procurement may need to consider alternative products or complementary hardware or plan for compensating controls. Require the developer of the system, system component, or system service to provide a description of the functional properties of the controls to be implemented.	No

Rank: 117	System and Services Acquisition #SA-4 (2)	Level: High
Acquisition Process | Design and Implementation Information for Controls OT Discussion: When acquiring OT products, consideration for security requirements may not have been incorporated into the design. Procurement may need to consider alternative products or complementary hardware or plan for compensating controls. Require the developer of the system, system component, or system service to provide design and implementation information for the controls that includes: [Selection (one or more): security-relevant external system interfaces; high-level design; low-level design; source code or hardware schematics; [Assignment: organization-defined design and implementation information]] at [*Assignment: organization-defined level of detail*].		No

Rank: 118	System and Services Acquisition #SA-4 (9)	Level: High

Acquisition Process | Functions, Ports, Protocols, and Services in Use OT Discussion: When acquiring OT products, consideration for security requirements may not have been incorporated into the design. Procurement may need to consider alternative products or complementary hardware or plan for compensating controls. Require the developer of the system, system component, or system service to identify the functions, ports, protocols, and services intended for organizational use.	No

Rank: 119	System and Services Acquisition #SA-4 (10)	Level: High
Acquisition Process | Use of Approved PIV Products OT Discussion: The use of approved PIV products is only required for organizations that follow OMB Memorandum M-19-17 (e.g., federal agencies and contractors). Example compensating controls include employing external products on the FIPS 201-approved products list for PIV capabilities in conjunction with OT products. Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems.		No

Rank: 120	System and Services Acquisition #SA-4 (12)	Level: High

Acquisition Process | Data Ownership Rationale for adding SA-4 (12) to LOW, MOD, and HIGH baselines: Organizationally sensitive or proprietary OT data is often provided to contractors for project development or support, so data ownership should be defined prior to exchanging data with a vendor or integrator. The potential sharing of data with other parties and the potential deletion of the data after project completion should be determined. OT systems that are operated by contractors on behalf of the organization may be subject to the same requirements (e.g., legal, regulatory, etc.) for data ownership and retention. (a) Include organizational data ownership requirements in the acquisition contract; and (b) Require all data to be removed from the contractor's system and returned to the organization within [*Assignment: organization-defined time frame*].	No

Rank: 121	System and Services Acquisition #SA-10	Level: High
OT Discussion: Personnel with knowledge about security and privacy requirements are included in the change management process for the developer. Require the developer of the system, system component, or system service to: a. Perform configuration management during system, component, or service [*Selection (one or more): design; development; implementation; operation; disposal*]; b. Document, manage, and control the integrity of changes to [*Assignment: organization-defined configuration items under configuration management*]; c. Implement only organization-approved changes to the system, component, or service; d. Document approved changes to the system, component, or service and the potential security and privacy impacts of such changes; and e. Track security flaws and flaw resolution within the system, component, or service and report findings to [*Assignment: organization-defined personnel*].		No

Rank: 122	System and Services Acquisition #SA-22	Level: High
OT Discussion: OT systems may contain system components that are no longer supported by the developer, vendor, or manufacturer and have not been replaced due to various operational, safety, availability, or lifetime constraints. Organizations identify alternative methods to continue supported operation of such system components and consider additional compensating controls to mitigate against known threats and vulnerabilities to unsupported system components. a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [Selection (one or more): in-house support; [Assignment: organization-defined support from external providers]].		No

Rank: 123	System and Communication Protection #SC-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] system and communications protection policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the system and communications protection policy and the associated system and communications protection controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the system and communications protection policy and procedures; and c. Review and update the current system and communications protection: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 124	System and Communication Protection #SC-2	Level: High
OT Discussion: Physical separation includes using separate systems for managing the OT and for operating OT components. Logical separation includes the use of different user accounts for administrative and operator privileges. Example compensating controls include providing increased auditing measures. Separate user functionality, including user interface services, from system management functionality.		No

Rank: 125	System and Communication Protection #SC-3	Level: High

OT Discussion: Organizations consider implementing this control when designing new architectures or updating existing components. An example compensating control includes access controls. Isolate security functions from nonsecurity functions.	No

Rank: 126	System and Communication Protection #SC-4	Level: High
OT Discussion: This control is especially relevant for OT systems that process confidential data. Example compensating controls include engineering the use of the OT to prevent sharing system resources. Prevent unauthorized and unintended information transfer via shared system resources.		No

Rank: 127	System and Communication Protection #SC-5	Level: High
OT Discussion: Some OT equipment may be more susceptible to DoS attacks due to the time criticality of some OT applications. Risk-based analysis informs the prioritization of DoS protection and the establishment of policy and procedure. a. [*Selection: Protect against; Limit*] the effects of the following types of denial-of-service events: [*Assignment: organization-defined types of denial-of-service events*]; and b. Employ the following controls to achieve the denial-of-service objective: [*Assignment: organization-defined controls by type of denial-of-service event*].		No

Rank: 128	System and Communication Protection #SC-7 (18)	Level: High

Boundary Protection | Fail Secure OT Discussion: The organization selects an appropriate failure mode (e.g., permit or block all communications). Rationale for adding SC-7 (18) to MOD baseline: The ability to choose the failure mode for the physical part of the OT differentiates the OT from other IT systems. This choice may be a significant influence in mitigating the impact of a failure. Prevent systems from entering unsecure states in the event of an operational failure of a boundary protection device.	No

Rank: 129	System and Communication Protection #SC-7 (28)	Level: High
Boundary Protection | Connections to Public Networks OT Discussion: Organizations consider the need for a direct connection to a public network for each OT system, including potential benefits, additional threat vectors, and potential adverse impacts that are specifically relevant to the type of public access that connection introduces. Rationale for adding SC-7 (28) to LOW, MOD, and HIGH baselines: Access to OT should be restricted to the individuals required for operation. A connection made from the OT directly to a public network has limited applicability in OT environments but significant potential risk. Prohibit the direct connection of [*Assignment: organization-defined system*] to a public network.		No

Rank: 130	System and Communication Protection #SC-7 (29)	Level: High

Boundary Protection | Separate Subnets to Isolate Functions OT Discussion: Subnets can be used to isolate low-risk functions from higher-risk ones and control from safety. Subnets should be considered along with other boundary protection technologies. Rationale for adding SC-7 (29) to LOW, MOD, and HIGH baselines: In OT environments, subnets and zoning are common practices for isolating functions. Implement [*Selection: physically; logically*] separate subnetworks to isolate the following critical system components and functions: [*Assignment: organization-defined critical system components and functions*].		No

Rank: 131	System and Communication Protection #SC-8 (1)	Level: High
Transmission Confidentiality and Integrity | Cryptographic Protection OT Discussion: When transmitting across untrusted network segments, the organization explores all possible cryptographic integrity mechanisms (e.g., digital signature, hash function) to protect the confidentiality and integrity of the information. Example compensating controls include physical protections, such as a secure conduit (e.g., point-to-point link) between two system components. Implement cryptographic mechanisms to [*Selection (one or more): prevent unauthorized disclosure of information; detect changes to information*] during transmission.		No

Rank: 132	System and Communication Protection #SC-10	Level: High

Rationale for removing SC-10 from MOD and HIGH baselines: The intent of this control is effectively covered by AC-17 (9) for OT systems. Terminate the network connection associated with a communications session at the end of the session or after [*Assignment: organization-defined time period*] of inactivity.	No

Rank: 133	System and Communication Protection #SC-23	Level: High
OT Discussion: Example compensating controls include auditing measures. Protect the authenticity of communications sessions.		No

Rank: 134	System and Communication Protection #SC-24	Level: High
OT Discussion: The organization selects an appropriate failure state. Preserving OT state information includes consistency among OT state variables and the physical state that the OT represents (e.g., whether valves are open or closed, communication permitted or blocked, continue operations). Rationale for adding SC-24 to MOD baseline: As part of the architecture and design of the OT, the organization selects an appropriate failure state in accordance with the function performed by the OT and the operational environment. The ability to choose the failure mode for the physical part of OT differentiates OT systems from other IT systems. This choice may be a significant influence in mitigating the impact of a failure since it may be disruptive to ongoing physical processes (e.g., valves failing in closed position may adversely affect system cooling). Fail to a [*Assignment: organization-defined known system state*] for the following failures on the indicated components while preserving [*Assignment: organization-defined system state information*] in failure: [*Assignment: list of organization-defined types of system failures on organization-defined system components*].		No

Rank: 135	System and Communication Protection #SC-28	Level: High
OT Discussion: Cryptographic mechanisms are implemented only after careful consideration and verification that they do not adversely impact the operational performance of the OT. When cryptographic mechanisms are not feasible on certain OT devices, compensating controls may include relocating the data to a location that does support cryptographic mechanisms. Protect the [*Selection (one or more): confidentiality; integrity*] of the following information at rest: [*Assignment: organization-defined information at rest*].		No

Rank: 136	System and Communication Protection #SC-32 (1)	Level: High
System Partitioning | Separate Physical Domains for Privileged Functions OT Discussion: Organizations consider separate physical domains for privileged functions, such as those that affect security and safety. Partition privileged functions into separate physical domains.		No

Rank: 137	System and Communication Protection #SC-39	Level: High
OT Discussion: Example compensating controls include partition processes to separate platforms. Maintain a separate execution domain for each executing system process.		No

Rank: 138	System and Communication Protection #SC-41	Level: High

Rationale for adding SC-41 to LOW, MOD, and HIGH baselines: OT functionality is generally defined in advance and does not change often. [*Selection: Physically; Logically*] disable or remove [*Assignment: organization-defined connection ports or input/output devices*] on the following systems or system components: [*Assignment: organization-defined systems or system components*].	No

Rank: 139	System and Communication Protection #SC-45	Level: High
OT Discussion: Organizations coordinate time synchronization on OT to allow for accurate troubleshooting and forensics. Rationale for adding SC-45 to LOW, MOD, and HIGH baselines: Organizations may find relative system time beneficial for many OT systems to ensure the safe and reliable delivery of essential functions. Time synchronization can also make root cause analysis more efficient by ensuring that audit logs from different systems are aligned so that organizations have an accurate view of events across multiple systems when the logs are aggregated. Synchronize system clocks within and between systems and system components.		No

Rank: 140	System and Communication Protection #SC-45 (1)	Level: High
System Time Synchronization | Synchronization with Authoritative Time Source OT Discussion: Syncing with an authoritative time source may be selected as a control when data is being correlated across organizational boundaries. OT employ suitable mechanisms (e.g., GPS, IEEE 1588) for timestamps. (a) Compare the internal system clocks [*Assignment: organization-defined frequency*] with [*Assignment: organization-defined authoritative time source*]; and (b) Synchronize the internal system clocks to the authoritative time source when the time difference is greater than [*Assignment: organization-defined time period*].		No

Rank: 141	System and Communication Protection #SC-47	Level: High
OT Discussion: Organizations consider which systems require alternate communication paths to ensure that a loss of communication does not lead to an unacceptable loss of view or control or to a safety event. Rationale for adding SC-47 to HIGH baseline: For continuity of operations during an incident, organizations should consider establishing alternate communications paths for command-and□control purposes to continue to operate and take appropriate actions for high-impact systems when the loss of availability or integrity may result in severe or catastrophic adverse impacts, including impacts to safety and critical service delivery. Establish [*Assignment: organization-defined alternate communications paths*] for system operations organizational command and control.		No

Rank: 142	System and Communication Protection #SC-51	Level: High
OT Discussion: Some OT systems support write-protection by implementing physical key switches or write-protect switches. Organizations define the systems for which write-protection will be enabled and develop a process for how to take the system out of write-protect mode. a. Employ hardware-based, write-protect for [*Assignment: organization-defined system firmware components*]; and b. Implement specific procedures for [*Assignment: organization-defined authorized individuals*] to manually disable hardware write-protect for firmware modifications and re-enable the write-protect prior to returning to operational mode.		No

Rank: 143	System and Information Integrity #SI-1	Level: High

OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] system and information integrity policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the system and information integrity policy and the associated system and information integrity controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the system and information integrity policy and procedures; and c. Review and update the current system and information integrity: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 144	System and Information Integrity #SI-2	Level: High

OT Discussion: Flaw remediation, or patching, is complicated since many OT employ OSs and other software that are no longer maintained by the vendors. OT operators may also not have the resources or capability to test patches and are dependent on vendors to validate the operability of a patch. Sometimes, the organization has no choice but to accept additional risk if no vendor patch is available, if patching requires additional time to complete validation or testing, or if deployment requires an unacceptable operations shutdown. In these situations, compensating controls should be implemented (e.g., limiting the exposure of the vulnerable system, restricting vulnerable services, implementing virtual patching). Other compensating controls that do not decrease the residual risk but increase the ability to respond may be desirable (e.g., provide a timely response in case of an incident, devise a plan to ensure that the OT can identify exploitation of the flaw). Testing flaw remediation in an OT may exceed the organization's available resources. a. Identify, report, and correct system flaws; b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation; c. Install security-relevant software and firmware updates within [*Assignment: organization-defined time period*] of the release of the updates; and d. Incorporate flaw remediation into the organizational configuration management process.	No

Rank: 145	System and Information Integrity #SI-3	Level: High

OT Discussion: Malicious code protection should only be deployed after careful consideration and verification that it does not adversely impact the operation of the OT. Malicious code protection tools should be configured to minimize their potential impact on the OT (e.g., employ notification rather than quarantine). Example compensating controls include increased traffic monitoring and auditing. a. Implement [*Selection (one or more): signature based; non-signature based*] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code; b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures; c. Configure malicious code protection mechanisms to: 1. Perform periodic scans of the system [*Assignment: organization-defined frequency*] and real-time scans of files from external sources at [*Selection (one or more): endpoint; network entry and exit points*] as the files are downloaded, opened, or executed in accordance with organizational policy; and 2. [Selection (one or more): block malicious code; quarantine malicious code; take [Assignment: organization-defined action]]; and send alert to [*Assignment: organization-defined personnel or roles*] in response to malicious code detection; and d. Address the receipt of false positives during malicious code detection and eradication and the resulting potential impact on the availability of the system.	No

Rank: 146	System and Information Integrity #SI-4	Level: High

OT Discussion: The organization ensures that the use of monitoring tools and techniques does not adversely impact the operational performance of the OT. Example compensating controls include deploying sufficient network, process, and physical monitoring. a. Monitor the system to detect: 1. Attacks and indicators of potential attacks in accordance with the following monitoring objectives: [Assignment: organization-defined monitoring objectives]; and 2. Unauthorized local, network, and remote connections; b. Identify unauthorized use of the system through the following techniques and methods: [*Assignment: organization-defined techniques and methods*]; c. Invoke internal monitoring capabilities or deploy monitoring devices: 1. Strategically within the system to collect organization-determined essential information; and 2. At ad hoc locations within the system to track specific types of transactions of interest to the organization; d. Analyze detected events and anomalies; e. Adjust the level of system monitoring activity when there is a change in risk to organizational operations and assets, individuals, other organizations, or the Nation; f. Obtain legal opinion regarding system monitoring activities; and g. Provide [*Assignment: organization-defined system monitoring information*] to [*Assignment: organization-defined personnel or roles*] [Selection (one or more): as needed; [Assignment: organization-defined frequency]].	No

Rank: 147	System and Information Integrity #SI-4 (2)	Level: High
System Monitoring | Automated Tools and Mechanisms for Real-time Analysis OT Discussion: When the OT cannot support the use of automated tools for near-real-time analysis of events, the organization employs compensating controls (e.g., providing an auditing capability on a separate system, nonautomated mechanisms or procedures) in accordance with the general tailoring guidance. Employ automated tools and mechanisms to support near real-time analysis of events.		No

Rank: 148	System and Information Integrity #SI-5	Level: High
OT Discussion: CISA generates security alerts and advisories relative to OT at https://www.cisa.gov/uscert/ics. Industry-specific ISACs often provide tailored advisories and alerts, which can be found at https://www.nationalisacs.org/. a. Receive system security alerts, advisories, and directives from [*Assignment: organization-defined external organizations*] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [Selection (one or more): [Assignment: organization-defined personnel or roles]; [Assignment: organization-defined elements within the organization]; [Assignment: organization-defined external organizations]]; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance.		No

Rank: 149	System and Information Integrity #SI-6	Level: High
OT Discussion: Shutting down and restarting the OT may not always be feasible upon the identification of an anomaly. These actions should be scheduled according to OT operational requirements. a. Verify the correct operation of [*Assignment: organization-defined security and privacy functions*]; b. Perform the verification of the functions specified in SI-6a [Selection (one or more): [Assignment: organization-defined system transitional states]; upon command by user with appropriate privilege; [Assignment: organization-defined frequency]]; c. Alert [*Assignment: organization-defined personnel or roles*] to failed security and privacy verification tests; and d. [Selection (one or more): Shut the system down; Restart the system; [Assignment: organization-defined alternative action(s)]] when anomalies are discovered.		No

Rank: 150	System and Information Integrity #SI-7	Level: High
OT Discussion: The organization determines whether the use of integrity verification applications would adversely impact operation of the ICS and employs compensating controls (e.g., manual integrity verifications that do not affect performance). a. Employ integrity verification tools to detect unauthorized changes to the following software, firmware, and information: [*Assignment: organization-defined software, firmware, and information*]; and b. Take the following actions when unauthorized changes to the software, firmware, and information are detected: [*Assignment: organization-defined actions*].		No

Rank: 151	System and Information Integrity #SI-7 (1)	Level: High
Software, Firmware, and Information Integrity | Integrity Checks OT Discussion: The organization ensures that the use of integrity verification applications does not adversely impact the operational performance of the OT. Perform an integrity check of [*Assignment: organization-defined software, firmware, and information*] [Selection (one or more): at startup; at [Assignment: organization-defined transitional states or security-relevant events]; [Assignment: organization-defined frequency]].		No

Rank: 152	System and Information Integrity #SI-7 (2)	Level: High

Software, Firmware, and Information Integrity | Automated Notifications of Integrity Violations OT Discussion: When the organization cannot employ automated tools that provide notifications about integrity discrepancies, the organization employs nonautomated mechanisms or procedures. Example compensating controls include performing scheduled manual inspections for integrity violations. Employ automated tools that provide notification to [*Assignment: organization-defined personnel or roles*] upon discovering discrepancies during integrity verification.	No

Rank: 153	System and Information Integrity #SI-7 (5)	Level: High
Software, Firmware, and Information Integrity | Automated Response to Integrity Violations OT Discussion: Shutting down and restarting the ICS may not always be feasible upon identification of an anomaly. These actions should be scheduled according to ICS operational requirements. Automatically [Selection (one or more): shut the system down; restart the system; implement [Assignment: organization-defined controls]] when integrity violations are discovered.		No

Rank: 154	System and Information Integrity #SI-7 (7)	Level: High

Software, Firmware, and Information Integrity | Integration of Detection and Response OT Discussion: When the ICS cannot detect unauthorized security□relevant changes, the organization employs compensating controls (e.g., manual procedures) in accordance with the general tailoring guidance. Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [*Assignment: organization-defined security-relevant changes to the system*].	No

Rank: 155	System and Information Integrity #SI-7 (15)	Level: High
Software, Firmware, and Information Integrity | Code Authentication OT Discussion: Code authentication provides assurance that the software and firmware have not been tampered with. If automated mechanisms are not available, organizations could manually verify code authentication by using a combination of techniques, including verifying hashes, downloading from reputable sources, verifying version numbers with the vendor, or testing software and firmware in offline or test environments. Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [*Assignment: organization-defined software or firmware components*].		No

Rank: 156	System and Information Integrity #SI-8	Level: High

OT Discussion: OT organizations implement spam protection by removing spam transport mechanisms, functions, and services (e.g., electronic mail, web browsing) from the OT. a. Employ spam protection mechanisms at system entry and exit points to detect and act on unsolicited messages; and b. Update spam protection mechanisms when new releases are available in accordance with organizational configuration management policy and procedures.	No

Rank: 157	System and Information Integrity #SI-8 (2)	Level: High
Spam Protection | Automatic Updates Rationale for removing SI-8 (2) from MOD and HIGH baselines: Spam transport mechanisms are disabled or removed from the OT, so automatic updates are not necessary. Automatically update spam protection mechanisms [*Assignment: organization-defined frequency*].		No

Rank: 158	System and Information Integrity #SI-13	Level: High

Rationale for adding SI-13 control to HIGH baseline: OT are designed and built with certain boundary conditions, design parameters, and assumptions about their environment and mode of operation. OT may run much longer than conventional systems, allowing latent flaws that are not manifest in other environments to become effective. For example, integer overflow might never occur in systems that are re-initialized more frequently than the occurrence of the overflow. Experience and forensic studies of anomalies and incidents in OT can lead to the identification of emergent properties that were previously unknown, unexpected, or unanticipated. Preventative and restorative actions (e.g., restarting the system or application) are prudent but may not be acceptable in OT for operational reasons. a. Determine mean time to failure (MTTF) for the following system components in specific environments of operation: [*Assignment: organization-defined system components*]; and b. Provide substitute system components and a means to exchange active and standby components in accordance with the following criteria: [*Assignment: organization-defined MTTF substitution criteria*].	No

Rank: 159	System and Information Integrity #SI-17	Level: High

OT Discussion: The selected failure conditions and corresponding procedures may vary among baselines. The same failure event may trigger different responses, depending on the impact level. Mechanical and analog systems can be used to provide mechanisms to ensure fail-safe procedures. Fail-safe states should incorporate potential impacts to human safety, physical systems, and the environment. A related controls is CP-6. Rationale for adding SI-17 to LOW, MOD, and HIGH baselines: This control provides a structure for the organization to identify its policy and procedures for dealing with failures and other incidents. Creating a written record of the decision process for selecting incidents and appropriate responses in light of a changing environment of operations is part of risk management. Implement the indicated fail-safe procedures when the indicated failures occur: [*Assignment: organization-defined list of failure conditions and associated fail-safe procedures*].	No

Rank: 160	System and Information Integrity #SI-22	Level: High
OT Discussion: Many OT systems use information diversity in their design to achieve reliability requirements. Some examples of information diversity for an OT system include sensor voting and state estimation. a. Identify the following alternative sources of information for [*Assignment: organization-defined essential functions and services*]: [*Assignment: organization-defined alternative information sources*]; and b. Use an alternative information source for the execution of essential functions or services on [*Assignment: organization-defined systems or system components*] when the primary source of information is corrupted or unavailable.		No

Rank: 161	Supply Chain Risk Management #SR-1	Level: High

OT Discussion: Supply chain policies and procedures for OT should consider both components received and components produced. Many OT systems use legacy components that cannot meet modern supply chain expectations. Appropriate compensating controls should be developed to achieve organizational supply chain expectations for legacy systems. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] supply chain risk management policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the supply chain risk management policy and the associated supply chain risk management controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the supply chain risk management policy and procedures; and c. Review and update the current supply chain risk management: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].	No

Rank: 162	Supply Chain Risk Management #SR-3 (1)	Level: High

Supply Chain Controls and Processes | Diverse Supply Base OT Discussion: Using a diverse set of suppliers in the OT environment can improve reliability by reducing common cause failures. This is not always possible since some technologies have limited supply options that meet the operational requirements. Employ a diverse set of sources for the following system components and services: [*Assignment: organization-defined system components and services*].	No

Rank: 163	Supply Chain Risk Management #SR-5 (1)	Level: High
Acquisition Strategies, Tools, and Methods |Adequate Supply OT Discussion: Vendor relationships and spare parts strategies are developed to ensure that an adequate supply of critical components is available to meet operational needs. Rationale for adding SR-5 (1) to MOD and HIGH baselines: OT systems and system components are often built for purpose and have a limited number of vendors or suppliers for a specific component. Organizations identify critical OT system components and controls to ensure an adequate supply in the event of supply chain disruptions. Employ the following controls to ensure an adequate supply of [*Assignment: organization-defined critical system components*]: [*Assignment: organization-defined controls*].		No

Questions Comments

There are no comments to display

Alternate Justification

Assessment, Authorization, and Monitoring - CA-7

Question:	OT Discussion: Continuous monitoring programs for OT are designed, documented, and implemented with input from OT personnel. The organization ensures that continuous monitoring does not interfere with OT functions. The individual or group designing and conducting the continuous monitoring for the OT systems implements a monitoring program that is consistent with the organizational information security policies and procedures, the OT security policies and procedures, and the specific health, safety, and environmental risks associated with a particular facility and/or process. Continuous monitoring can be automated or manual at a frequency sufficient to support risk-based decisions. For example, the organization may monitor event logs manually on a specified frequency less often for lower-risk, isolated systems than for higher-risk, networked systems. Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy that includes: a. Establishing the following system-level metrics to be monitored: [*Assignment: organization-defined system-level metrics*]; b. Establishing [*Assignment: organization-defined frequencies*] for monitoring and [*Assignment: organization-defined frequencies*] for assessment of control effectiveness; c. Ongoing control assessments in accordance with the continuous monitoring strategy; d. Ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy; e.	Alternate

	Correlation and analysis of information generated by control assessments and monitoring; f. Response actions to address results of the analysis of control assessment and monitoring information; and g. Reporting the security and privacy status of the system to [*Assignment: organization-defined personnel or roles*] [*Assignment: organization-defined frequency*].	
Alternate Justification:	Security Onion	

Questions Marked for Review

There are no questions marked for review.